

Anders Linde



Introduction to Key Information Security Standards

OWASP Aarhus

1

Information security principles



Confidentiality

DISCLOSURE:

- Leak of int. strategies
- Managers share employee health data
- Employees talk openly about case management

Integrity

ALTERATION:

- Faulty updating of systems
- Errors in printing files
- Hackers' modification of customer data

Availability

DENIAL:

- Flooding of archives in the basement
- Denial-of-service attacks
- Ransomware Hits Case Management System

ISO 27 - all rights reserved

2

Information security at a glance



Information security

Protect the confidentiality, integrity and availability of information to realize the organization's goals.

KL:

The municipalities must follow the principles of the standard



ISO/IEC 27001:

An Information Security Management System (ISMS)

CISO27 - all rights reserved

3

Management standards



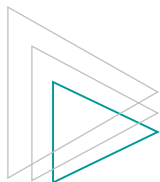
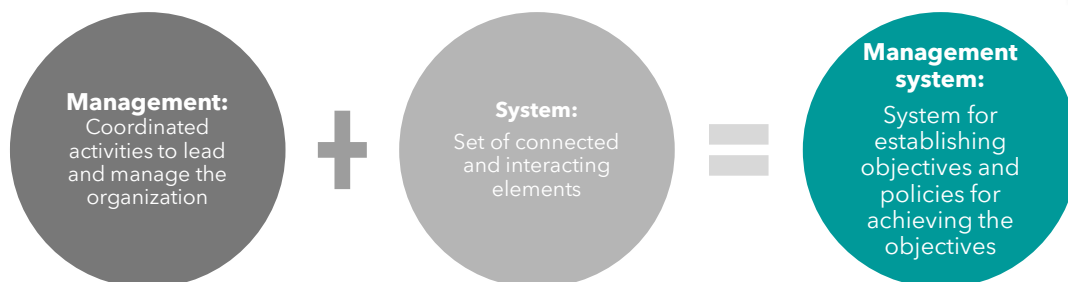
Harmonized structure (HS)



CISO27 - all rights reserved

4

A management system



CISO27 - all rights reserved

5

Maximum versus relevant security

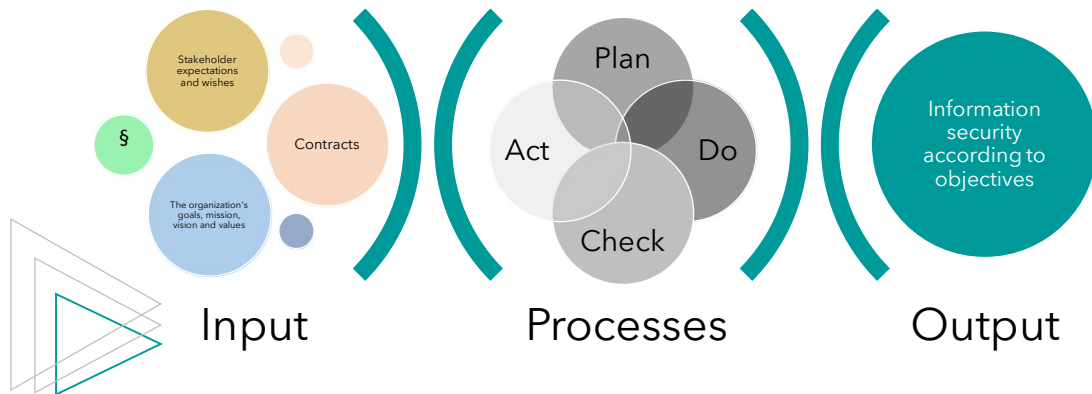


CISO27 - all rights reserved

6

Process approach to information security

ISO²⁷
Underpinning & underpinning |
standard for cyber resilience

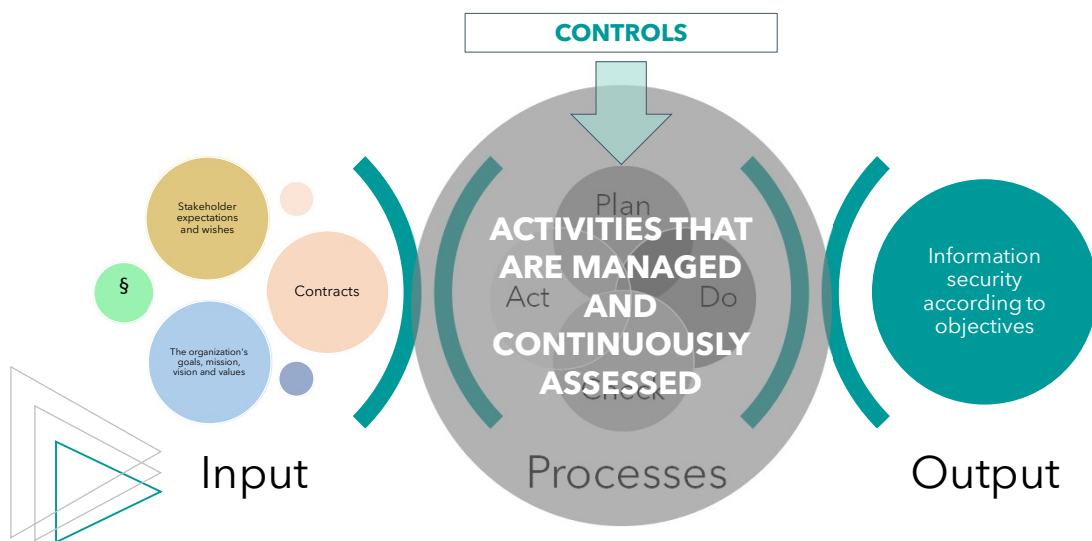


ISO27 - all rights reserved

7

Process approach to information security

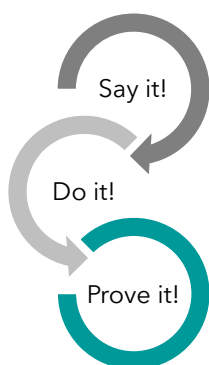
ISO²⁷
Underpinning & underpinning |
standard for cyber resilience



ISO27 - all rights reserved

8

ISO/IEC 27001: auditability



Explain how the tasks are performed!

Show me how it's done!

Document that it has been done!

ISO27 - all rights reserved

9

ISO/IEC 27001 in summary



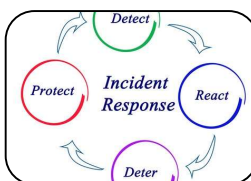
Protect information

- We protect against loss of confidentiality, integrity and availability



Conduct risk assessments

- We assess the organisation's risk profile and take appropriate measures



Make continuous improvements

- We follow up on our investment in information security



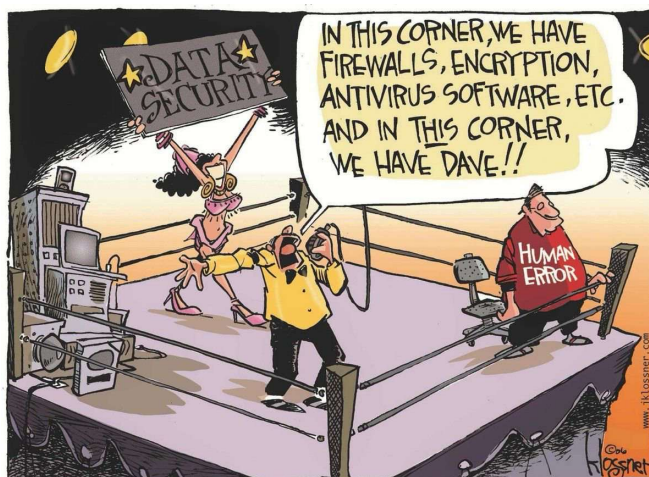
Documenting our efforts

- We explain what we do and document that it is being done

ISO27 - all rights reserved

10

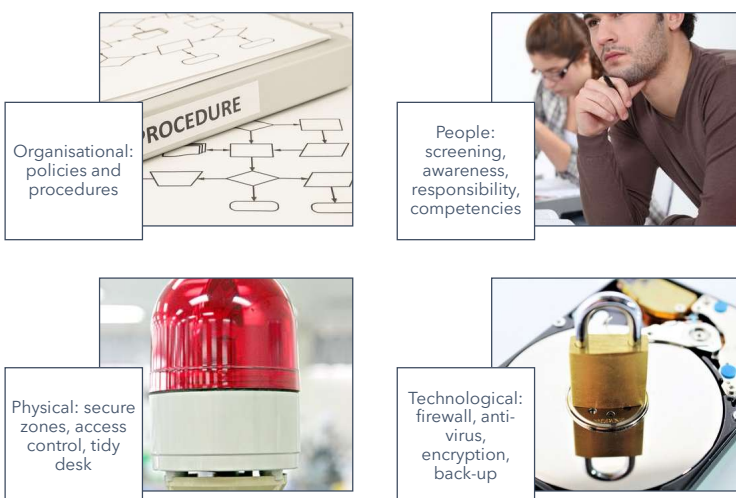
Information versus IT security



CISO27 - all rights reserved

11

ISO/IEC 27002: guidance on controls



CISO27 - all rights reserved

12

8.33 Information for testing

CISO²⁷

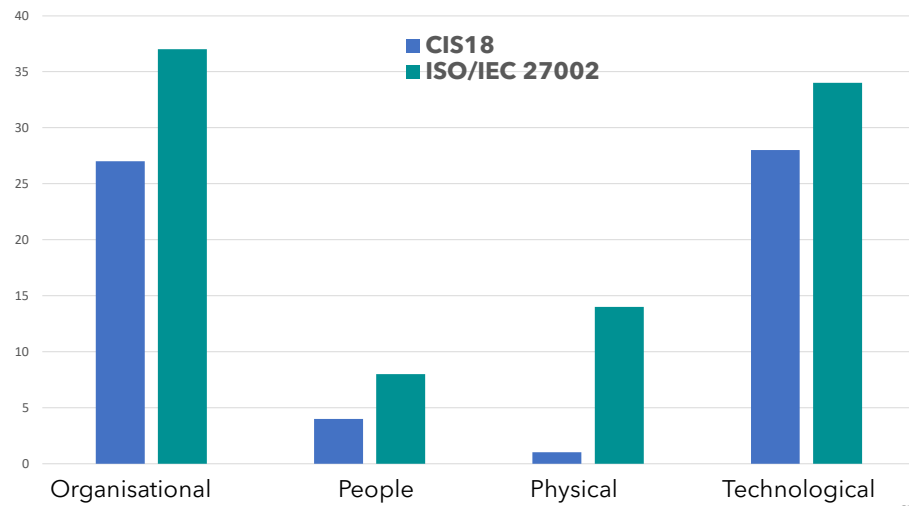
CIS Critical Security Controls
Version 8
 Mapping to ISO/IEC 27002:2022

CIS Center for Internet Security®

CIS Controls

2	2.3	Applications	Identity	Enterprise
2	2.3	Introduction	Li	

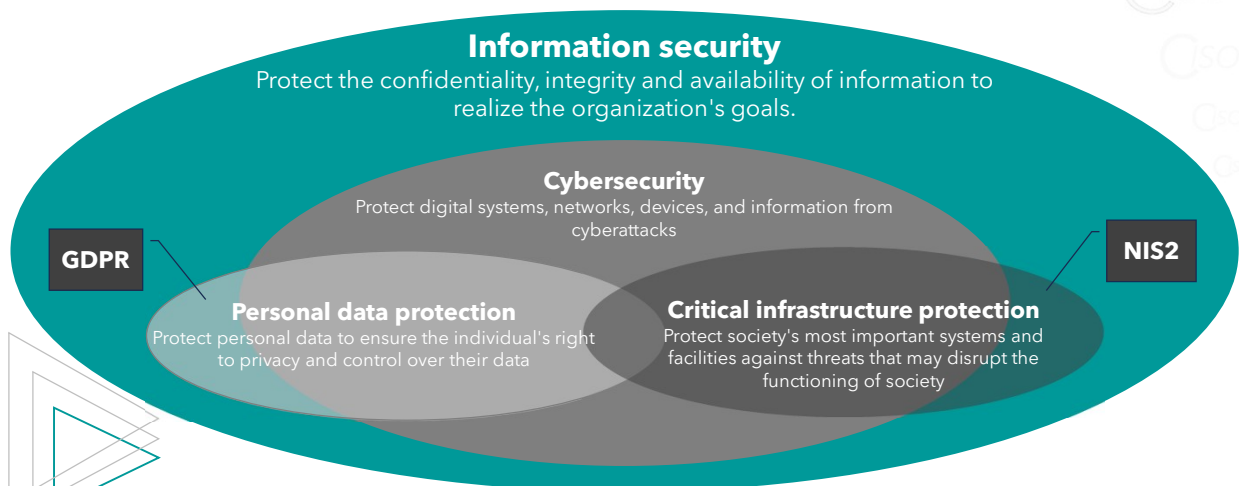
CIS18 overlap with ISO/IEC 27002



CISO27 - all rights reserved

15

Overview of regulation

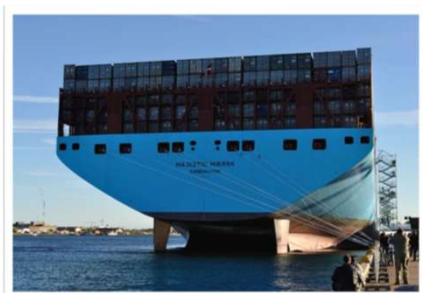


CISO27 - all rights reserved

16

The business... and GDPR privacy concerns

CISO²⁷
Underpinning & bridging |
standards for cybersecurity



"... maintain the confidentiality, integrity and availability of information through a risk management process..."

ISO/IEC 27001



"... protect the privacy that could potentially be affected by the processing of personal data"

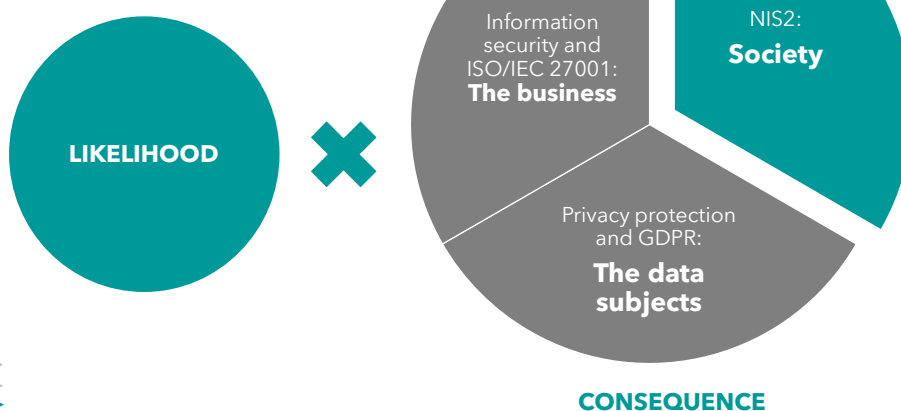
ISO/IEC 27701

CISO27 - all rights reserved

17

NIS2 perspective

CISO²⁷
Underpinning & bridging |
standards for cybersecurity



CISO27 - all rights reserved

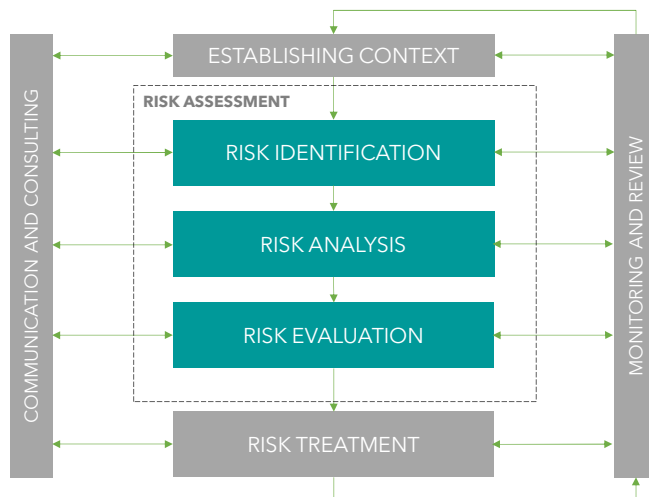
18

ISO/IEC 27005: Risk management guidance



"This document provides guidance on implementation of the information security risk requirements specified in ISO/IEC 27001:2022"

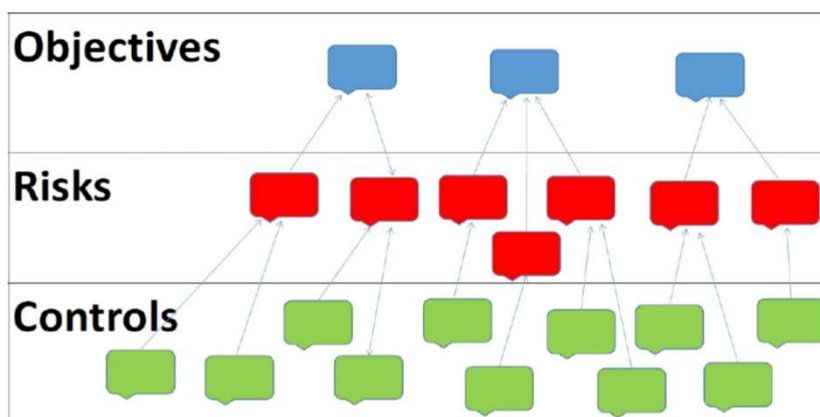
ISO/IEC 27005:2022, introduction



ISO27 - all rights reserved

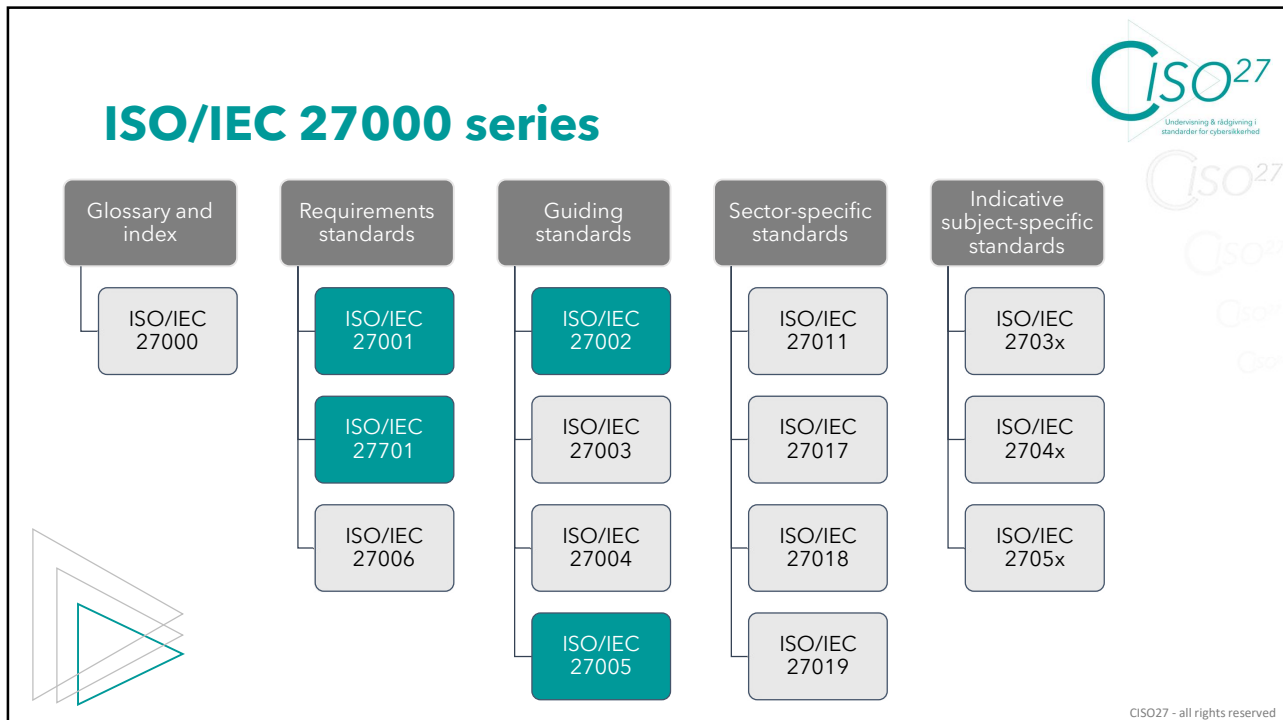
19

Uncover the business significance



ISO27 - all rights reserved

20



21



22











2025 NATIONALT RISIKOBILLEDE

<https://samsik.dk>

Vurderingen af cybertruslen mod Danmark pr. januar 2025

Cyberkriminalitet	MEGET HØJ
Cyberspionage	MEGET HØJ
Cyberaktivisme	HØJ
Destruktive cyberangreb	MIDDEL
Cyberterror	INGEN



CISO27 - all rights reserved

23











AI changing the terms of the business

AI-system



Threats

Medical Diagnosis System

Consequences

Chatbot on a website

Facial recognition system at airports

CISO27 - all rights reserved

24

AI Act - another European legal act



CISO27



GDPR

Binding legal act on personal data and data protection



NIS2

A common goal to secure critical infrastructure in selected sectors



AI Act

Binding act on responsible use for AI

CISO27 - all rights reserved

25

ISO/IEC 42001: Responsible use of AI



CISO27

Objectives

- Accountability
- Transparency
- Fairness
- Environmental impact
- Maintainability
- Reliability
- Safety
- Robustness
- Accessibility
- Security
- Privacy



CISO27 - all rights reserved

26

ISO/IEC 42001: Expanding the toolbox



Policies Related to AI
(A.2)



Internal Organization
(A.3)



Resources for AI
Systems (A.4)



Assessing Impacts of
AI Systems (A.5)



AI System Life Cycle
(A.6)



Data for AI Systems
(A.7)



Information for
Interested Parties
(A.8)



Use of AI Systems
(A.9)



Third-Party and
Customer
Relationships (A.10)

CISO27 - all rights reserved

27

Anders Linde



Thank you for your time!

anders@ciso27.dk
Tlf. 6162 1500

28